

Lab 4: Basic Port Scanning

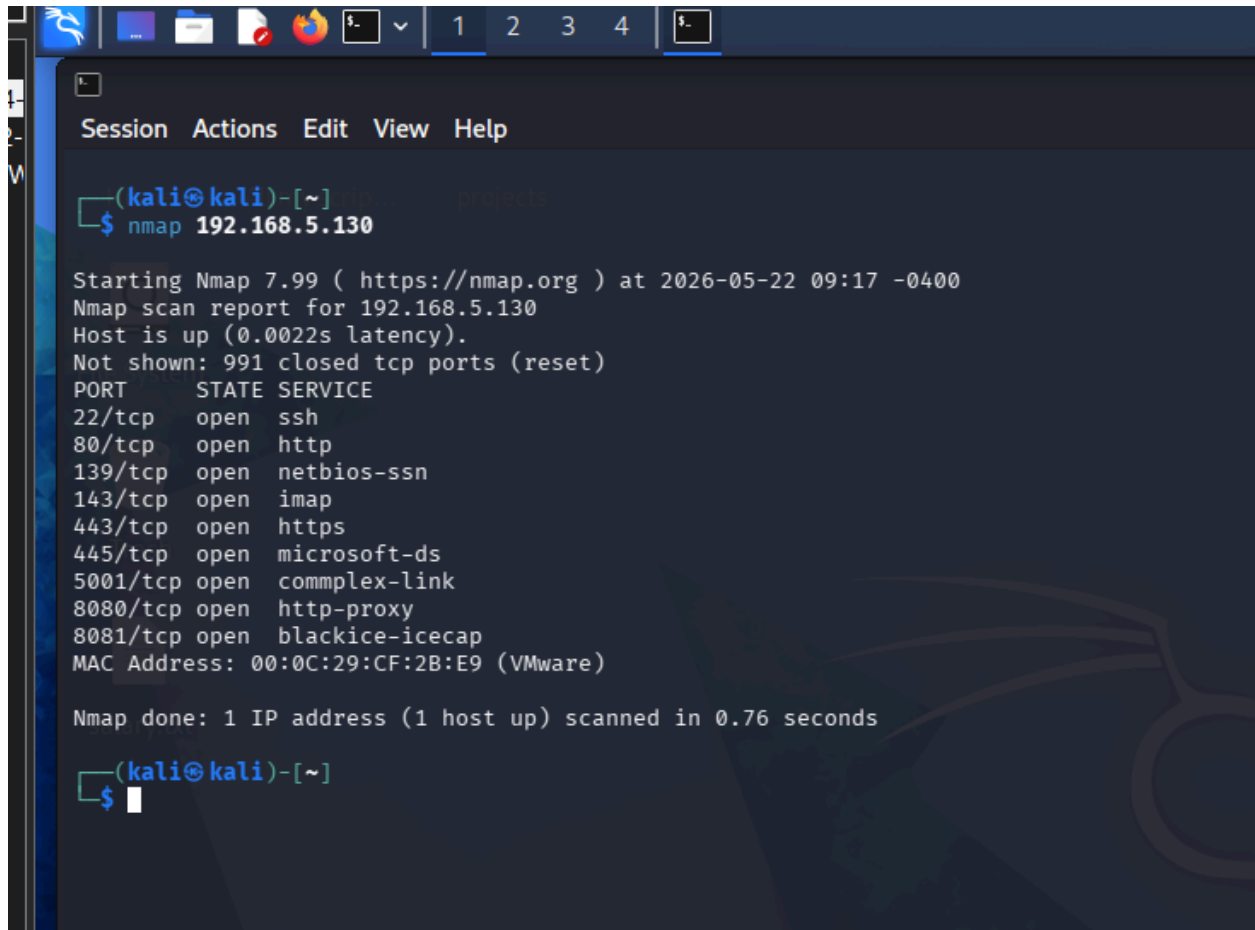
Tools Used

- Kali Linux
- nmap
- Nikto

Exercise 1:

Perform a basic port scan on your OWASP VM IP address and record

Command Used: nmap 192.168.5.130



```
(kali@kali)-[~]
$ nmap 192.168.5.130

Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-22 09:17 -0400
Nmap scan report for 192.168.5.130
Host is up (0.0022s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp    open  netbios-ssn
143/tcp    open  imap
443/tcp    open  https
445/tcp    open  microsoft-ds
5001/tcp   open  complex-link
8080/tcp   open  http-proxy
8081/tcp   open  blackice-icecap
MAC Address: 00:0C:29:CF:2B:E9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.76 seconds

(kali@kali)-[~]
$
```

findings:

- Open Ports: 8080,22,80,139,143,443,445,5001 and port 8081
-

Exercise 2:

Perform an aggressive scan on your OWASP VM IP address

Command used: `nmap -sV -O 192.168.5.130`

```
kali@kali:~$ nmap -sV -O 192.168.5.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-22 09:24 -0400
Nmap scan report for 192.168.5.130
Host is up (0.0018s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.3p1 Debian 3ubuntu4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL ...)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap         Courier Imapd (released 2008)
443/tcp   open  ssl/http     Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL ...)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
5001/tcp  open  java-object  Java Object Serialization
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8081/tcp  open  http         Jetty 6.1.25
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port5001-TCP:V=7.99%I=7%O=5/22%Time=6A105928%P=x86_64-pc-linux-gnu%r(NU
SF:LL,4,"xac\xed\0\x05");
MAC Address: 00:0C:29:CF:2B:E9 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.17 - 2.6.36
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.42 seconds
```

findings:

Service Versions:

- OpenSSH 5.3p1 Debian 3ubuntu4
- Apache httpd 2.2.14
- Samba smbd 3.x – 4.x
- Courier IMAP (2008 release)
- Apache httpd 2.2.14 (SSL)
- Samba smbd 3.x – 4.x
- Java Object Serialization (port 5001)
- Apache Tomcat/Coyote JSP engine 1.1

- Jetty 6.1.25

Operating System:

- Linux 2.6.17 – 2.6.36 (Ubuntu Linux)
- VMware virtual machine

Exercise 3:

Conduct a vulnerability scan on your OWASP VM IP address

Commands Used: `nmap --script vuln 192.168.5.130`

```
kali@kali: ~  
$ nmap --script vuln 192.168.5.130  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-22 09:42 -0400  
Nmap scan report for 192.168.5.130  
Host is up (0.0022s latency).  
Not shown: 991 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
| http-enum:  
| /wordpress/: Blog  
| /test/: Test page  
| /mono/: Mono  
| /crossdomain.xml: Adobe Flash crossdomain policy  
| /phpmyadmin/: phpMyAdmin  
| /wordpress/wp-login.php: Wordpress login page.  
| /cgi-bin/: Potentially interesting folder w/ directory listing  
| /icons/: Potentially interesting folder w/ directory listing  
| /images/: Potentially interesting folder w/ directory listing  
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.  
| http-cookie-flags:  
| /mono/:  
|   ASP.NET_SessionId:  
|   httponly flag not set  
|_ http-cross-domain-policy:  
|   VULNERABLE:  
|   Cross-domain and Client Access policies.  
|   State: VULNERABLE  
|   A cross-domain policy file specifies the permissions that a web client such as Java, Adobe Flash, Adobe Reader,  
|   etc. use to access data across different domains. A client access policy file is similar to cross-domain policy  
|   but is used for M$ Silverlight applications. Overly permissive configurations enables Cross-site Request  
|   Forgery attacks, and may allow third parties to access sensitive data meant for the user.  
|   Check results:  
|   /crossdomain.xml:  
|   <?xml version="1.0"?>  
|   <!DOCTYPE cross-domain-policy SYSTEM "http://www.macromedia.com/xml/dtds/cross-domain-policy.dtd">  
|   <cross-domain-policy>  
|   <allow-access-from domain="*" />  
|   </cross-domain-policy>  
|   Extra information:  
|   Trusted domains:*  
|  
|   References:  
|   https://www.adobe.com/devnet/articles/crossdomain_policy_file_spec.html  
|   https://www.adobe.com/devnet-docs/acrobatetk/tools/AppSec/CrossDomain_PolicyFile_Specification.pdf  
|   http://acunetix.com/vulnerabilities/web/insecure-clientaccesspolicy-xml-file  
|   https://www.owasp.org/index.php/Test_RIA_cross_domain_policy_%28OTG-CONFIG-008%29
```

findings:

Vulnerabilities:

- Cross-domain and Client Access policy misconfiguration (/crossdomain.xml)
- Apache byterange filter DoS (CVE-2011-3192)
- HTTP TRACE method enabled
- Internal IP disclosure (127.0.1.1)
- CSRF vulnerabilities (multiple forms on WordPress, Rails Goat, phpBB2, etc.)
- SSL/TLS CCS Injection (CVE-2014-0224)
- Weak Diffie-Hellman group (1024-bit MODP)

- SSL POODLE vulnerability (CVE-2014-3566)
 - Missing HTTPOnly cookie flag (ASP.NET_SessionId)
 - Missing Secure cookie flag (HTTPS session cookies)
 - Directory listing enabled (/cgi-bin/, /icons/, /images/)
 - phpMyAdmin exposed (/phpmyadmin/)
 - WordPress login exposed (/wordpress/wp-login.php)
 - Apache Tomcat admin endpoints exposed (/manager/html, /upload)
 - Potential SQL injection script failure (http-sql-injection script error reported)
-

Exercise 4:

Vulnerability scan on OWASP VM and record your

Commands Used:

1. nikto -h 192.168.5.130

```
Home X kali-linux-2025.4-vmware-a... X OWASP Broken Web Apps VM v... X
1 2 3 4
kali@kali -
Session Actions Edit View Help

--(kali@kali)~--
$ nikto -h 192.168.5.130
- Nikto v2.6.0

+ Target IP: 192.168.5.130
+ Target Hostname: 192.168.5.130
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-22 09:53:32 (GMT-4)

+ Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
+ ERROR: Failed to check for updates: 403
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 286483, size: 28067, mtime: Thu Jul 30 22:55:52 2015. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [750500] /icons/: Directory indexing found.
+ [750500] /cgi-bin/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [500670] /favicon.ico: identifies this app/server as: owasp.org. See: https://en.wikipedia.org/wiki/Favicon
+ [600625] PHP/5.3.2-1ubuntu4.30 appears to be outdated (current is at least 8.5.1).
+ [600595] OpenSSL/0.9.8k appears to be outdated (current is at least 3.6.0). OpenSSL 1.1.1w is current for 1.x and is supported via contract, and 3.0.12 for 3.0.x, and 3.1.4 for 3.1.x.
+ [600620] proxy_html/3.0.1 appears to be outdated (current is at least 3.1.2).
+ [600620] Perl/v5.10.1 appears to be outdated (current is at least v5.36.3).
+ [600511] mod_ssl/2.2.14 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ [600475] mod_mono/2.4.3 appears to be outdated (current is at least 3.13).
+ [600932] Phusion_Passenger/4.0.38 appears to be outdated (current is at least 6.0.14).
+ [600050] Apache/2.2.14 appears to be outdated (current is at least 2.4.66).
+ [600652] Python/2.6.5 appears to be outdated (current is at least 3.13.1).
+ [600487] mod_perl/2.0.4 appears to be outdated (current is at least 2.0.13).
+ [600494] mod_python/3.3.1 appears to be outdated (current is at least 3.5.0).
+ [999979] /images: IP address found in the 'location' header. The IP is '127.0.1.1'. See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [999988] /images: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is '127.0.1.1'. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: List.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.css, index.html. See: https://www.wisec.it/sectou.php?id=4698bdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [800132] /: mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
+ [800262] /: PHP/5.3 - PHP 3/4/5 and 7.0 are End of Life products without support.
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [999986] /phpBB2/search.php?search_id=1\\: Retrieved x-powered-by header: PHP/5.3.2-1ubuntu4.30.
+ [95] /phpBB2/search.php?search_id=1\\: Cookie phpbb2owaspbwa_data created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [95] /phpBB2/search.php?search_id=1\\: Cookie phpbb2owaspbwa_sid created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
```

findings:

Vulnerabilities Found:

- ETags inode leakage (CVE-2003-1418)
- Directory indexing enabled (/icons/, /cgi-bin/, /test/, /images/)

- Outdated Apache 2.2.14
- Outdated PHP 5.3.2 (EOL)
- Outdated OpenSSL 0.9.8k (EOL)
- Outdated Python 2.6.5 (EOL)
- Outdated Perl 5.10.1 (EOL)
- Outdated mod_ssl 2.2.14 (possible RCE risk)
- Outdated mod_mono 2.4.3
- Outdated Phusion Passenger 4.0.38
- Outdated mod_perl 2.0.4
- Outdated mod_python 3.3.1
- Internal IP disclosure (127.0.1.1 via Location header)
- Missing security headers:
 - HSTS
 - CSP
 - X-Content-Type-Options
 - Referrer-Policy
 - Permissions-Policy
- mod_negotiation MultiViews enabled (file brute-force risk)
- HTTP TRACE method enabled (XST risk)
- OPTIONS method enabled (GET, POST, TRACE, OPTIONS)
- mod_ssl buffer overflow risk (legacy versions)
- phpMyAdmin exposed (/phpmyadmin/)
- WordPress login exposed (/wordpress/wp-login/)
- phpBB cookies missing HttpOnly flag
- Apache default file exposed (/icons/README)
- Potential sensitive test directory exposed (/test/)